



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report

Site: <http://172.30.19.2:3000>

Generated on Sun, 26 Jul 2026 17:50:59

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	3
Low	3
Informational	3
False Positives:	0

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	3
Missing Anti-clickjacking Header	Medium	2
Vulnerable JS Library	Medium	1
Cookie without SameSite Attribute	Low	5
Timestamp Disclosure - Unix	Low	4
X-Content-Type-Options Header Missing	Low	Systemic
Information Disclosure - Suspicious Comments	Informational	2
Session Management Response Identified	Informational	4
User Agent Fuzzer	Informational	Systemic

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://172.30.19.2:3000

Node Name	http://172.30.19.2:3000
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.30.19.2:3000/login
Node Name	http://172.30.19.2:3000/login
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.30.19.2:3000/sitemap.xml
Node Name	http://172.30.19.2:3000/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://172.30.19.2:3000
Node Name	http://172.30.19.2:3000
Method	GET
Attack	
Evidence	
Other Info	

URL	http://172.30.19.2:3000/login
Node Name	http://172.30.19.2:3000/login
Method	GET
Attack	
Evidence	
Other Info	
Instances	2
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium	Vulnerable JS Library
Description	The identified library appears to be vulnerable.
URL	http://172.30.19.2:3000/public/build/vendor.0cea50118711e7e6c839.js
Node Name	http://172.30.19.2:3000/public/build/vendor.0cea50118711e7e6c839.js
Method	GET
Attack	
Evidence	* jQuery JavaScript Library v3.2.1
Other Info	The identified library jquery, version 3.2.1 is vulnerable. CVE-2020-11023 CVE-2020-11022 CVE-2019-11358 https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/ https://nvd.nist.gov/vuln/detail/CVE-2019-11358 https://github.com/jquery/jquery/commit/753d591aea698e57d6db58c9f722cd0808619b1b https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/
Instances	1
Solution	Upgrade to the latest version of the affected library.
Reference	https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
CWE Id	1395
WASC Id	
Plugin Id	10003

Low	Cookie without SameSite Attribute
------------	--

Description	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	http://172.30.19.2:3000
Node Name	http://172.30.19.2:3000
Method	GET
Attack	
Evidence	Set-Cookie: grafana_sess
Other Info	
URL	http://172.30.19.2:3000
Node Name	http://172.30.19.2:3000
Method	GET
Attack	
Evidence	Set-Cookie: redirect_to
Other Info	
URL	http://172.30.19.2:3000/
Node Name	http://172.30.19.2:3000/
Method	GET
Attack	
Evidence	Set-Cookie: grafana_sess
Other Info	
URL	http://172.30.19.2:3000/
Node Name	http://172.30.19.2:3000/
Method	GET
Attack	
Evidence	Set-Cookie: redirect_to
Other Info	
URL	http://172.30.19.2:3000/sitemap.xml
Node Name	http://172.30.19.2:3000/sitemap.xml
Method	GET
Attack	
Evidence	Set-Cookie: grafana_sess
Other Info	
Instances	5
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

CWE Id	1275
WASC Id	13
Plugin Id	10054

Low	Timestamp Disclosure - Unix
Description	A timestamp was disclosed by the application/web server. - Unix
URL	http://172.30.19.2:3000
Node Name	http://172.30.19.2:3000
Method	GET
Attack	
Evidence	1524755363
Other Info	1524755363, which evaluates to: 2018-04-26 15:09:23.
URL	http://172.30.19.2:3000/login
Node Name	http://172.30.19.2:3000/login
Method	GET
Attack	
Evidence	1524755363
Other Info	1524755363, which evaluates to: 2018-04-26 15:09:23.
URL	http://172.30.19.2:3000/public/build/app.3095c117813e1134f897.js
Node Name	http://172.30.19.2:3000/public/build/app.3095c117813e1134f897.js
Method	GET
Attack	
Evidence	1492750877
Other Info	1492750877, which evaluates to: 2017-04-21 05:01:17.
URL	http://172.30.19.2:3000/sitemap.xml
Node Name	http://172.30.19.2:3000/sitemap.xml
Method	GET
Attack	
Evidence	1524755363
Other Info	1524755363, which evaluates to: 2018-04-26 15:09:23.
Instances	4
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

--	--

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://172.30.19.2:3000/public/build/grafana.dark.css?v5.1.0
Node Name	http://172.30.19.2:3000/public/build/grafana.dark.css (v5.1.0)
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.30.19.2:3000/public/build/manifest.b79f256681fa503ac2ed.js
Node Name	http://172.30.19.2:3000/public/build/manifest.b79f256681fa503ac2ed.js
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.30.19.2:3000/public/img/fav32.png
Node Name	http://172.30.19.2:3000/public/img/fav32.png
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.30.19.2:3000/public/img/grafana_mask_icon.svg
Node Name	http://172.30.19.2:3000/public/img/grafana_mask_icon.svg
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.

URL	http://172.30.19.2:3000/robots.txt
Node Name	http://172.30.19.2:3000/robots.txt
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	http://172.30.19.2:3000/public/build/0.a84ed159b378acd7d9f2.js
Node Name	http://172.30.19.2:3000/public/build/0.a84ed159b378acd7d9f2.js
Method	GET
Attack	
Evidence	* The buffer module from node.js, for the br
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: "/*! * The buffer module from node.js, for the browser. * * @author Feross Aboukhadijeh <feross@feross.org> <http://feross.o", see evidence field for the suspicious comment/snippet.
URL	http://172.30.19.2:3000/public/build/vendor.0cea50118711e7e6c839.js
Node Name	http://172.30.19.2:3000/public/build/vendor.0cea50118711e7e6c839.js
Method	GET
Attack	
Evidence	son.github.io/react-select */
Other Info	The following pattern was used: \bSELECT\b and was detected in likely comment: "/*! Copyright (c) 2017 Jed Watson. Licensed under the MIT License (MIT), see

	http://jedwatson.github.io/react-select */", see evidence field for the suspicious comment/snippet.
Instances	2
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://172.30.19.2:3000
Node Name	http://172.30.19.2:3000
Method	GET
Attack	
Evidence	grafana_sess
Other Info	cookie:grafana_sess
URL	http://172.30.19.2:3000/
Node Name	http://172.30.19.2:3000/
Method	GET
Attack	
Evidence	grafana_sess
Other Info	cookie:grafana_sess
URL	http://172.30.19.2:3000/sitemap.xml
Node Name	http://172.30.19.2:3000/sitemap.xml
Method	GET
Attack	
Evidence	grafana_sess
Other Info	cookie:grafana_sess
URL	http://172.30.19.2:3000
Node Name	http://172.30.19.2:3000
Method	GET
Attack	
Evidence	grafana_sess
Other	

Info	cookie:grafana_sess
Instances	4
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Informational	User Agent Fuzzer
Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://172.30.19.2:3000/
Node Name	http://172.30.19.2:3000/
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://172.30.19.2:3000/public
Node Name	http://172.30.19.2:3000/public
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://172.30.19.2:3000/public/build
Node Name	http://172.30.19.2:3000/public/build
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104